RAPPORT TP 3.1 — Attaque d’un serveur Linux (Ubuntu)

1. Introduction

Il est question pour nous de comprendre comment un attaquant peut compromettre un serveur Linux via :

-Une attaque par brute force SSH (mot de passe faible)

-Exploitation d'un service vulnérable

- **Vérification préalable du laboratoire**

Avant toute attaque, j'ai vérifié que la communication entre les deux machines fonctionnait.

```
┌──(merdouce㉿kali)-[~]
└─$ ping 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=0.411 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=0.454 ms
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=0.453 ms
64 bytes from 192.168.56.10: icmp_seq=4 ttl=64 time=0.425 ms
64 bytes from 192.168.56.10: icmp_seq=5 ttl=64 time=0.486 ms
64 bytes from 192.168.56.10: icmp_seq=6 ttl=64 time=0.464 ms
64 bytes from 192.168.56.10: icmp_seq=7 ttl=64 time=0.497 ms
64 bytes from 192.168.56.10: icmp_seq=8 ttl=64 time=0.434 ms
64 bytes from 192.168.56.10: icmp_seq=9 ttl=64 time=0.412 ms
^C
```

J'ai également vérifié que le service SSH était actif sur Ubuntu :

sudo systemctl status ssh

```
merdouce@virtualBox:~$ sudo systemctl start ssh
[sudo] Mot de passe de merdouce :
merdouce@virtualBox:~$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enab>
     Active: active (running) since Tue 2026-04-28 13:09:18 WAT; 1min 52s ago
 Invocation: 178c8ca18abf44fc8cc34d2dd2a93c52
TriggeredBy: ● ssh.socket
       Docs: man:sshd(8)
             man:sshd_config(5)
    Process: 1317 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 1346 (sshd)
      Tasks: 1 (limit: 1879)
     Memory: 1.6M (peak: 2.1M)
        CPU: 40ms
     CGroup: /system.slice/ssh.service
             └─1346 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

avril 28 13:09:17 virtualBox systemd[1]: Starting ssh.service - OpenBSD Secure >
avril 28 13:09:18 virtualBox sshd[1346]: Server listening on 0.0.0.0 port 22.
avril 28 13:09:18 virtualBox systemd[1]: Started ssh.service - OpenBSD Secure S>
avril 28 13:09:18 virtualBox sshd[1346]: Server listening on :: port 22.
lines 1-19/19 (END)
```

2. Attaque par mot de passe faible (Brute Force SSH)

Objectif

Tester la robustesse des identifiants SSH des l'utilisateurs

Outil utilisé : Hydra

Hydra est un outil de brute force permettant de tester des combinaisons login/mot de passe sur différents services (SSH, FTP, HTTP, etc.).

hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10 -t 4

Option Signification

-l Login unique

-P Fichier de mots de passe (rockyou.txt)

-t 4 4 tâches parallèles

- Extraction de rockyou

```
┌──(merdouce㉿kali)-[~]
└─$ hydra -l student -p /usr/share/wordlists/rockyou.txt  ssh: 192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-28 14:27:
36
[ERROR] Unknown service: 192.168.56.10
```

```
┌──(merdouce㉿kali)-[~]
└─$ gzip -d /usr/share/worlists/rockyou.txt.gz
gzip: /usr/share/worlists/rockyou.txt.gz: No such file or directory

┌──(merdouce㉿kali)-[~]
└─$
```

- Exploitation des vulnerabilities

3. Exploitation d'un service vulnérable (vsftpd 2.3.4)

Objectif

Exploiter le backdoor présent dans vsftpd 2.3.4 pour obtenir un shell root.

- **Installation du service FTP**

```
merdouce@virtualBox:~$ sudo apt install vsftpd -y
Installation de :
  vsftpd

Sommaire :
  Mise à niveau de : 0. Installation de : 1Supprimé : 0. Non mis à jour : 0
Taille du téléchargement : 131 kB
  Espace nécessaire : 333 kB / 15,7 GB disponible

Ign : 1 http://archive.ubuntu.com/ubuntu plucky/main amd64 vsftpd amd64 3.0.5-0.
1
Ign : 1 http://archive.ubuntu.com/ubuntu plucky/main amd64 vsftpd amd64 3.0.5-0.
1
```

- **Vérification de la version du service FTP**

```
root@virtualBox:/home/merdouce# vsftpd -v
vsftpd: version 3.0.5
root@virtualBox:/home/merdouce#
```

Exploitation avec Metasploit

Le backdoor (exploit vsftpd_234_backdoor) n'existe QUE pour la version 2.3.4, et encore, seulement pour les binaires compromis téléchargés sur le site officiel en juillet 2011.

la cible : vsftpd 3.0.5 → PAS VULNÉRABLE

L'exploit que he tentez : vsftpd 2.3.4 → NE CORRESPOND PAS

```
root@kali: /home/merdouce

┌──(root㉿kali)-[/home/merdouce]
└─# msfconsole
Metasploit tip: When in a module, use back to go back to the top level
prompt

IIIIII    dTb.dTb        _.---._
  II     4'  v  'B   .'"".'/|\`."".'
  II     6.     .P  :  .' / | \ `.  :
  II     'T;. .;P'  '.'  /  |  \  `.'
  II      'T; ;P'    `. /   |   \ .'
IIIIII     'YvP'       `-.__|__.-'

I love shells --egypt


       =[ metasploit v6.4.126-dev                         ]
+ -- --=[ 2,638 exploits - 1,331 auxiliary - 2,146 payloads     ]
+ -- --=[ 431 post - 49 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

4. Analyse et compréhension

Rappel des actions réalisées par l'attaquant

- Détection du service SSH ouvert
- Attaque par brute force (Hydra) sur le compte student
- Mot de passe faible trouvé : 123456
- Connexion SSH réussie

Ce que l'attaquant peut faire après compromission

Une fois connecter au compte student l'attaquant peut :

Explorer l'arborescence du serveur : ls -la, cd, pwd

Lire les fichiers utilisateur : cat /home/auilabs/document.txt

Identifier les autres utilisateurs : cat /etc/passwd

Chercher des mots de passe stockés : grep -r "password" /home/auilabs/

Tenter une élévation de privilèges : sudo -l

Avec un accès root(via vsftp 2.3.4), l'attaquant contrôle entièrement le serveur

5. Utilisation avance des outils

hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10 -t 4

Option Signification

-l Login unique

-P Fichier de mots de passe (rockyou.txt)

-t 4 4 tâches parallèles

6. Recommandation de sécurité

-Mettre a jour vsftpd

-Désactiver l'authentification par mot de passe

-Activer e pare-feu

-Utiliser un mot de passe fort pour sécuriser son compte utilisateur

7. CONCLUSION

Ce travail pratique visait à comprendre comment un attaquant peut exploiter des faiblesses simples mais critiques sur un serveur Linux :

- Des mots de passe faibles (attaque par brute force SSH)
- Un service obsolète (vsftpd 2.3.4 avec backdoor)

L'objectif n'était pas simplement d'exécuter des outils, mais de comprendre la réalité et l'impact d'une compromission dans un contexte professionnel comme celui de l'entreprise NetSecure.